The University Spirit in the Digital Age

For an Open, Secure and Mission-Aligned Digital Infrastructure

Edition of the University of Luxembourg

Executive Summary addressed to the University Bodies

Companion to: *"The University Spirit in the Digital Age — For an Open, Secure and Mission-Aligned Digital Infrastructure"*

Edition version 2.1.2 · tracks SUIT suite 1.0.4

Visibility: PUBLIC (published in the SUIT working-group repository)

Status: Approved by the Faculty of Science, Technology and Medicine and the Department of Computer Science of the University of Luxembourg on May 7, 2026

Scope: a faculty-level endorsement of the proposal (Faculty Council of the Faculty of Science, Technology and Medicine, and Department of Computer Science), not an adoption by the University; the proposal is in the University's governance process

Based on the SUIT Working Group [1↗]

Author and contact: Nicolas Guelfi, Department of Computer Science, University of Luxembourg (chair of the SUIT working group, creator of the first version) — nicolas.guelfi@uni.lu

Print date: November 3, 2026

A segmented architecture with flexible secure contexts for a modern university — where digital security and academic missions reinforce each other

On the nature of this companion. *This document is the executive summary of a voluntary contribution produced by members of the academic community acting in their scientific and technical capacity, addressed to the institution's governing bodies (the Faculty Councils and the University Council, and the Board of Governors) for consideration and, if found substantive, propagation by the Board of Governors (Conseil de Gouvernance) to all concerned components.*

© SUITOAA

Key messages

- **Digital freedom is the rule** in a university; restrictions must be proportionate, documented, and limited to what is strictly necessary. When a contract or a regulation would invert that order, the institution's first reflex is to renegotiate or to engage in reform — not to comply by default (the main report's liberty-first rule).
- **Segment to protect, liberate to excel:** a multi-zone architecture with Trusted Activity Contexts strengthens security for sensitive data while granting autonomy to research and teaching.
- **Democratic governance of digital policy:** a Digital Policy Commission chaired by an elected academic formulates proposals endorsed by the unit-level deliberative bodies and the institution-wide council.
- **Proven and progressive:** the approach is validated by peer research institutions, international standards, and the applicable regulatory framework; it can be deployed incrementally, starting with a pilot on selected entities.

The university spirit: openness as a foundational principle

From the *Magna Charta Universitatum* (Bologna, 1988) to the UNESCO *Recommendation on Science and Scientific Researchers* (2017), a universal consensus holds: the university is a space of **intellectual freedom**, **free movement of people and ideas**, and **autonomy** for academic staff. This openness is not a luxury — it is the very condition under which knowledge is produced and transmitted. Today, the digital space is the primary space where this movement occurs. **A digital policy that is restrictive by default is contrary to the university spirit.**

Founding principle

A university requires administration, but is not a corporation; university governance must optimise for freedom for ideas and persons, physical or digital. The digital infrastructure should reflect this fundamental distinction.

In a university, **digital freedom is the rule**. Any restriction must be *explicitly justified* by a documented risk, *proportionate* to that risk, and *limited to the strictly necessary scope* — a specific laboratory, a specific project, a specific dataset — never applied uniformly across the entire institution.

This principle reflects the risk-based, proportionate-measures requirement that runs through modern data-protection and cybersecurity frameworks — in the European Union, General Data Protection Regulation (GDPR) Article 32 (*measures appropriate to the risk*) and the NIST Cybersecurity Framework 2.0 (*risk-based approach*) are canonical references — and it is consistent with the practice of leading research universities.

▷ *Full analysis and references: the sections Summary for stakeholders, Introduction and Specificities of universities regarding IS in the complete suite [1↗].*

What the university spirit demands of digital infrastructure

Effects of uniform restriction policies

A policy that treats financial data and research GPU clusters identically generates several documented effects: it concentrates risk on a single perimeter (a breach can affect the institution as a whole — as recent breaches in the sector have shown); it correlates with the

Historical university principle	Digital translation (at the University of Luxembourg, as of 31 October 2026)
Free movement of persons	✗ Functional BYOD, ✓ eduroam, ✗ seamless researcher mobility
Free movement of ideas	★ unfiltered Internet access, ★ major cloud-based AI services, ★ worldwide scientific sources
Teacher-researcher autonomy	✗ local admin privileges (root/admin), ✗ freedom of tool choice, ✗ configurable environments
Scientific openness (Open Science)	★ access to data platforms, ★ code repositories, ✓ open-access publications
Realistic training environments	★ configurable labs, ✗ cyber-ranges, ★ API access for AI courses

✓ Available ★ To be reinforced ✗ Not available

emergence of Shadow IT (researchers may turn to unsupervised solutions); it is associated with talent mobility patterns toward institutions with more flexible IT environments; and it affects competitiveness in European and international grant calls. Restrictive policies can also expose the institution to *litigation based on fundamental rights* (academic freedom, freedom of expression and information, dignity at work).

Guiding principle for institutional resilience

A university information system must not attempt to prevent all errors, experiments, or unforeseen uses; it must **prevent such events from compromising the institution as a whole**.

In short: local freedom, incident confinement, protection of the core, global resilience.

What the most publicised recent university incidents actually show

The most publicised university breaches of recent years — whether at large national research universities or through shared platform and enterprise-software vulnerabilities such as those affecting widely used managed file-transfer and ERP products — share **the same root causes**: third-party/supply-chain vulnerabilities, credential compromise, and centralised perimeters without internal boundaries. **None of the major recent data breaches analysed here were caused by research-zone autonomy.** Known incidents involving research infrastructure — such as the 2020 European supercomputer attacks, where stolen SSH credentials were used for cryptomining on High-Performance Computing (HPC) systems at several national academic computing centres including ETH Zurich's CSCS [2↗] — involved unauthorized access rather than data exfiltration, and would have been mitigated by the Trusted Activity Context mechanisms proposed here: credentials scoped to a specific activity context cannot grant lateral access to other contexts or to the infrastructure core. They demonstrate the urgent need for *segmentation and context-bounded access* — precisely what this proposal advocates.

▷ *Full analysis and references: the sections Shadow IT: documented effects of restrictive policies, Fundamental principle: dependability, Media-Covered Failures in Universities (2024–2025): Context and Lessons and Justification and Feasibility in the complete suite [1↗].*

The proposal: segment to liberate, Trusted Activity Contexts for individualised protection

The logic is simple: **secure strongly what must be secured** (administrative, financial, HR data — and any data of equivalent sensitivity wherever it sits) **to liberate everything else**. This is what MIT, Stanford, Oxford, ETH Zurich, Cambridge, CERN, Michigan and EPFL do — and, through their national research-and-education networks, what institutions of far more modest scale do as well — and what NIST, ISO 27001 and Control Objectives for Information and Related Technologies (COBIT) recommend. These are not a flagship's choices to borrow but a minimal set every institution offering a digital infrastructure must discharge; only the instantiation varies with size, not the obligation.

The proposed architecture rests on two complementary mechanisms: *segmentation* controls where incidents can spread (network boundaries); **Trusted Activity Contexts** provide each user with a validated environment — assembling data, tools, services, and access rights — adapted to their current role and task. Together, they are designed to contain a breach within its context, subject to tested boundaries and documented exceptions, rather than letting it cascade to the rest of the institution.

Conceptually, the university information system is organised in **concentric layers** (the executive view of the five structural layers detailed in the main report): a small, strongly protected **infrastructure core** (identity, network backbone, backups, supervision) that forms the *dependability foundation* of the institution; **common services** (messaging, Learning Management System (LMS), collaboration) available to all; **autonomous zones** (research, teaching) with local freedom and bounded impact; **exposed zones** (public-facing services and portals, isolated from the internal system by DMZ-type architectures); and **user networks** (Bring Your Own Device (BYOD), Wi-Fi) that are open but isolated from the core. Protecting the small critical core is what makes it possible to liberate everything else.

The six principal operational zones below map onto these layers (a seventh IoT/Building zone is detailed in the technical report):

Zone	Philosophy	Constraint level
Research	**Maximum openness** — autonomy, root access, worldwide AI cloud, local server management	Minimal: responsibility charter, monitoring
Teaching	**Broad openness** — discipline-specific environments for all faculties, AI APIs, cyber-ranges, VDI	Standard: pedagogical framework
Staff BYOD	**Free Internet** + progressive access to institutional resources	MFA + minimal posture check
Research-data path (e.g. Science DMZ)	**Maximum performance** — high-throughput transfers without stateful firewall	ACL + dedicated IDS
Administrative	**Maximum protection** — this is where restrictions are concentrated by default; the sensitive enclave carries equivalent controls wherever the data class requires them	Strict: firewall, IDS/IPS, proxy, full GDPR
Sensitive enclave	Case by case, **at project level**	Only on explicit, documented justification

Key point: restrictions at laboratory or project level apply **only when explicit and**

documented reasons require them (medical data, classified projects, specific funding constraints such as NIST SP 800-171). In the absence of such justification, the laboratory benefits from the **maximum openness policy** of the research zone. The default is freedom; the exception is restriction.

All zones lie within the cybersecurity-baseline perimeter applicable to the institution under its entity classification; calibration of controls follows the risk-proportionality principle of that regime — the NIS2 Directive (NIS2) Article 21 measure families in the worked EU instantiation — not scope reduction. The function this discharges is the cybersecurity risk-governance obligation (F2) of the Regulatory Applicability annex (Part IV of the complete dossier); read your own regime's instrument for that obligation in the regime typology there.

▷ *Full analysis and references: the sections State of the art: university infrastructure architectures, Examples of universities with decentralised architecture, Artificial intelligence and access to cloud services and Proposed infrastructure and organisational solutions in the complete suite [1↗].*

Governance aligned with the university spirit

- **Digital Policy Commission** chaired by an *elected* academic, composed of representatives from the constituent academic units (departments and interdisciplinary centres) across the institution. The Commission formulates policy proposals that are submitted to the unit-level deliberative bodies and then to the institution-wide council for endorsement. The IT-management lead and the information-security-management lead submit proposals; the Commission decides — aligned with COBIT 2019's separation of governance (strategic direction) from management (operational execution) and with established academic-governance practice;
- **Responsibility charters** (as practised across research institutions): autonomy is formalised and accountable, replacing informal exceptions;
- **Contextual role management:** a single individual (e.g. a researcher who also teaches and administers a laboratory) activates only the relevant role for each task — never carrying all privileges simultaneously. This enforces least privilege, improves auditability, and maps naturally onto the zone structure;
- **Open-source and open-science tools as default institutional choices**, reducing vendor lock-in, increasing transparency, and aligning with public-sector open-source strategies (e.g., the European Commission's in the EU);
- **Independent Commission for Reasonable Adjustments of Digital Policies** (Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP)): any employee can challenge a disproportionate restriction — for medical, personal, professional reasons, or infringement of fundamental freedoms — in accordance with the EU Charter of Fundamental Rights, the CRPD Convention and the case law of the Court of Justice of the European Union (CJEU) and the European Court of Human Rights (ECtHR) on the proportionality of digital restrictions. The institution already operates a reasonable-adjustments mechanism (supporting students and staff); the ICRADP extends that established principle to digital policies. Refusals must be justified in writing.

Continuous-improvement mechanism. Together, the Digital Policy Commission, the unit-level deliberative bodies, the responsibility charters and the ICRADP constitute the institution's continuous-improvement mechanism, materialised in the annual compliance and maturity report submitted to the competent cybersecurity authority [3↗] pursuant to the continuous-improvement provision of the applicable regime — see the Regulatory Applicability annex (Part IV of the complete dossier), the accountability-and-conformity obligation (F6) under your regime profile, instantiated in the worked EU example by the Luxembourg Law of 5 May

2026 on measures for a high level of cybersecurity (Mémorial A No. 225 of 6 May 2026, in force since 10 May 2026), transposing Directive (EU) 2022/2555 [4↗].

▷ *Full analysis and references: the sections Federated IT Governance, Contextual role management and separation of privileges, Propositions and Independent Commission for Reasonable Adjustments to Digital Policies in the complete suite [1↗].*

Feasibility: progressive, controlled, affordable

Step	Content
1. Governance	Digital Policy Commission, responsibility charters, service catalogue, formalised exception path
2. Pilot	Segmented architecture and Trusted Activity Contexts deployed on a pilot technical department, a pilot research centre, and the University's HPC team (ULHPC) together with the Department of Computer Science (DCS) and the SnT (the Interdisciplinary Centre for Security, Reliability and Trust) — high-throughput research-data path (Science DMZ), BYOD zone, open-source tools
3. Progressive extension	Gradual rollout to other departments, faculties and centres, progressive Zero Trust, AI research zone, audit and continuous improvement

No "big bang" required. The governance step is organisational and achievable with existing staff. The pilot and progressive extension rely on RESTENA (the Luxembourg national research and education network) and its international research-backbone services, open-source tools, and platforms offered free of charge for academic research.

Scale-appropriate reading. Where public documentation evidences no Science DMZ — nor any equivalent research-and-education-network-operated research-data path — deployed, neither at the institution nor at RESTENA (the Luxembourg national research and education network) level, the substrate is nonetheless frequently already operational: high-capacity backbone connectivity to the international research backbone through RESTENA (the Luxembourg national research and education network), an HPC facility moving petabyte-scale traffic, and RESTENA-CSIRT (the CSIRT of the Luxembourg NREN RESTENA) [5↗] for incident response. For institutions of modest scale, the pragmatic form is therefore not an institution-only deployment of the Science DMZ pattern but a federated research-network zone — the same high-throughput research-data path realised at national, mutualised scale — *co-designed* with RESTENA (the Luxembourg national research and education network) and shared across partner research organisations, with a dedicated medical enclave for biomedical workloads where required.

▷ *Full analysis and references: the sections NREN status: what is typically in place, what is missing, Justification and Feasibility and Transition Plan, and the standalone Technical Reference [6↗] (vendor-neutral architecture, sovereignty grid, migration playbook) in the complete suite [1↗].*

Current regulatory and operational context

1. **AI as a structural tool for research and teaching:** research and teaching access to major cloud-based and open AI services (commercial APIs and open model hubs) is now part of the standard scientific working environment. Under the EU AI Act (Regulation (EU) 2024/1689)'s risk-based framework — the technology-governance obligation (F5) of the Regulatory Applicability annex (Part IV of the complete dossier) — the resulting obligations depend on the concrete use case and the user's role; many research uses of

commercial AI services fall outside the high-risk categories. Under the proposed cooperative researcher-centred model (PI data classification + institutional register maintained by the central IT function + periodic audit by the data-protection function), the cross-border-transfer obligation (F4) bites: in the worked EU instantiation, the *Schrems II* cumulative regime applies to personal-data transfers [7↗]. The AI regime's research-and-development exemption (where one exists — e.g. Art. 2(6) of the EU AI Act) covers bespoke research tools, not the use of commercial APIs.

2. **The applicable regulatory framework demands it:** the data-protection security-of-processing obligation (F1) requires *proportionate* measures — GDPR Article 32 in the worked EU instantiation; under the cybersecurity-baseline regime (F2), instantiated here by the national transposition of NIS2 [4↗], the institution is classified by the ILR (the Institut Luxembourgeois de Régulation, the Luxembourg NIS2 supervisory authority) as an **essential entity** (holistic perimeter, proactive supervision, mandatory audits, annual maturity report via SERIMA (the Luxembourg SEcurity RIsk MAnagement incident-notification platform, operational since 2 May 2025) [8↗]) [3↗]; sector cybersecurity guidance from the relevant sector authority treats cybersecurity as a strategic governance risk [9↗]; a segmented architecture aligned with NIS2 Article 21 proportionality is the appropriate response. The instruments named here are the EU instantiation of a jurisdiction-invariant obligation spine; an adopter reads its own regime's instruments for these obligations in the Regulatory Applicability annex (Part IV of the complete dossier).
3. **Reference universities providing comparable openness:** ETH Zurich, EPFL, Oxford, Cambridge, MIT, Stanford and many others provide their researchers with the autonomy and infrastructure described here. The RESTENA (the Luxembourg national research and education network) and its international backbone interconnect make the same architectural primitives accessible at the institution's national scale.

▷ *Full analysis and references: the sections European regulatory context and Artificial intelligence and access to cloud services in the complete suite [1↗].*

A matter of institutional coherence

Call to action

The university cannot proclaim academic freedom in its statutes and impose a uniform digital lockdown in its daily practice. Providing an **open, segmented and proportionately secured** framework means honouring the university spirit while **strengthening security** where it is truly necessary — rather than weakening the institution through blanket restrictions that drive talent away and fuel Shadow IT.

Short-term objectives:

1. That **the relevant Faculty Council(s), then the University Council**, and finally **the Board of Governors**, endorse a position statement derived from the present executive summary, *"The University Spirit in the Digital Age"*;
2. That the **executive leadership**, in collaboration with IT experts and academic representatives, define a short- to medium-term implementation plan aligned with the architecture described in the accompanying technical report and developed in detail in the standalone Technical Reference [6↗].

Accompanying documents: *"The University Spirit in the Digital Age — For an Open, Secure and Mission-Aligned Digital Infrastructure"*. The report provides the full state of the art, an international set of university case studies, European regulatory analysis, detailed architecture, cost-benefit analysis, transition

plan with risk register and KPIs, and the complete legal and normative foundations for the ICRADP. A standalone Technical Reference [6↗] addressed to chief technology officers and information-security officers develops a five-dimension sovereignty grid, a vendor-neutral reference architecture demonstrated on open foundations, and a wave-based migration playbook. It is intended as the shared technical baseline for the international university network anticipated in phase 2 of this initiative.

Note on the process: *This document is an always living document. It is provided for constructive feedback and revision in order to improve its quality. The engineering of this document was partially supported by digital tools, some of which incorporate Artificial Intelligence features.*

References

[1] SUIT Working Group. *SUIT — Sustainable University IT Infrastructure & Technology*. SUIT Working Group reference document suite. Reference document suite of the SUIT Working Group, https://github.com/suit-working-group. Always-living document. 2026. URL: https://github.com/suit-working-group/suit-suite.

[2] BleepingComputer. *European supercomputers hacked in mysterious cyberattacks*. May 2020 coordinated intrusion campaign against European HPC centres (ARCHER at Edinburgh, several bwHPC clusters, HLRS Stuttgart, and the Swiss National Supercomputing Centre (CSCS), operated by ETH Zurich). Investigated by the EGI-CSIRT. 2020. URL: https://www.bleepingcomputer.com/news/security/european-supercomputers-hacked-in-mysterious-cyberattacks/.

[3] Institut Luxembourgeois de Régulation. *Classification of the University of Luxembourg as an essential entity under the NIS2 transposition (written confirmation reported by the University CISO)*. Attestation on file: e-mail of the University CISO of 3 April 2026, 10:50, at the Department of Computer Science (no attachment; the ILR document itself is not on file). Not public. 2026. URL: https://web.ilr.lu/.

[4] Grand-Duché de Luxembourg. *Loi du 5 mai 2026 concernant des mesures destinées à assurer un niveau élevé de cybersécurité (transposition de la Directive (UE) 2022/2555, dite NIS2)*. Mémorial A n° 225 du 6 mai 2026, Journal officiel du Grand-Duché de Luxembourg. Published 6 May 2026; entry into force 10 May 2026 (ILR). Supersedes projet de loi 8364 as the reference for the NIS2 sections of the edition; the bill stays cited as legislative history. 2026. URL: https://legilux.public.lu/eli/etat/leg/loi/2026/05/05/a225/jo.

[5] Restena Foundation. *RESTENA-CSIRT — Computer Security Incident Response Team of the Luxembourg NREN*. 2026. URL: https://www.restena.lu/en/security.

[6] SUIT Working Group. *Sustainable University IT — A Technical Reference for Architecture and Migration*. Technical reference and migration playbook. Companion technical document to the report *The University Spirit in the Digital Age — For an Open, Secure and Mission-Aligned Digital Infrastructure*. Produced by the SUIT Working Group, https://github.com/suit-working-group. Always-living document; version 2.1, May 2026. SUIT Working Group, 2026. URL: https://github.com/suit-working-group/suit-suite.

[7] CJUE (Grande Chambre). *Data Protection Commissioner c. Facebook Ireland et Schrems*. Aff. C-311/18, 16 juillet 2020 — This decision profoundly impacts university IT infrastructure, requiring institutions to reassess all data transfers to third countries, particularly when using US-based cloud computing platforms, learning management systems, and research collaboration tools. 2020. URL: https://curia.europa.eu/juris/liste.jsf?num=C-311/18.

[8] Institut Luxembourgeois de Régulation. *SERIMA — SEcurity RIsk MAnagement platform*. 2026. URL: https://www.ilr.lu/en/sectors/niss/serima/.

[9] Jisc. *Cyber Security Guidance for Boards and Senior Leaders in Higher Education*. Written by David Batho, Jisc's Director of Security. Directly addresses how university leadership should approach cybersecurity oversight and institutional defense strategies as a board-level priority, drawing from the Association of Colleges Governance Professionals Conference. 2024. URL: https://www.jisc.ac.uk/blog/cyber-resilience-a-strategic-board-level-priority.